Détection DDoS et généralisation à des attaques non observées

DAF-Projet — S9

2026

Question centrale

Un modèle entraîné sur certaines attaques DDoS reconnaît-il une stratégie DDoS jamais rencontrée ?

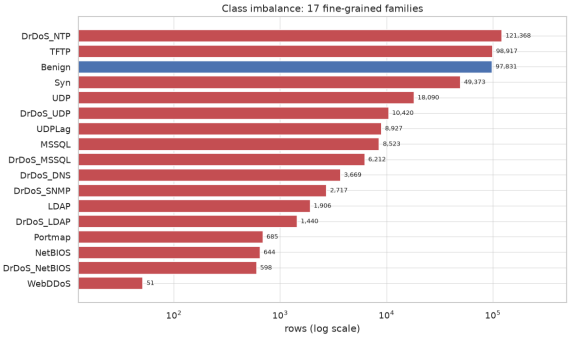
H1 — le multiclasses est plus difficile que le binaire.

H2 — la généralisation dépend fortement de la famille laissée de côté.

H3 — une fraction des variables conserve l'essentiel de la performance.

Données : 431 371 flux, 17 familles

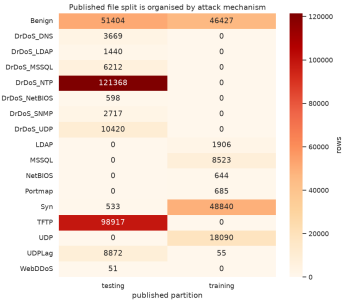
- CIC-DDoS2019, 17 fichiers Parquet, 77 features.
- 21 347 lignes dans des groupes de doublons exacts.
- 8 858 empreintes présentes dans plus d’un fichier.
- 5 289 empreintes avec labels contradictoires.
- Après dédoublonnage : **418 884 lignes**.



Le piège du split publié

- `-testing` : toutes les familles `DrDoS_*` + TFTP + WebDDoS.
- `-training` : LDAP, MSSQL, NetBIOS, Portmap, UDP.
- Seules `Benign`, `Syn`, `UDPLag` chevauchent les deux.

Utiliser ce split mesure la reconnaissance d'un **mécanisme**, pas la généralisation. Il est écarté.



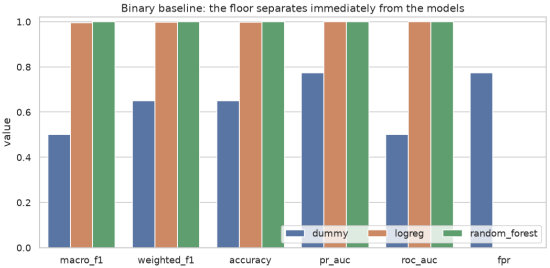
Protocole sans fuite

1. Dédoublonner **avant** le split (une ligne par empreinte).
2. Ignorer le split publié.
3. Split stratifié 80/20 sur la famille fine, une fois par graine.
4. Preprocessing dans une `Pipeline` : colonnes constantes → scale → modèle.
5. LOADO : purger la famille des **17 fichiers**, pas du fichier homonyme.
6. Métriques : Macro-F1, rappel par classe, PR-AUC, FPR à TPR 95 %.

Baseline binaire

- Dummy stratifié : Macro-F1 = 0.501.
- Régression logistique : Macro-F1 = 0.995, FPR = 0.0026.
- Forêt aléatoire : Macro-F1 = 0.999, FPR = 0.0003.

Le binaire est **facile** : une frontière linéaire suffit presque.



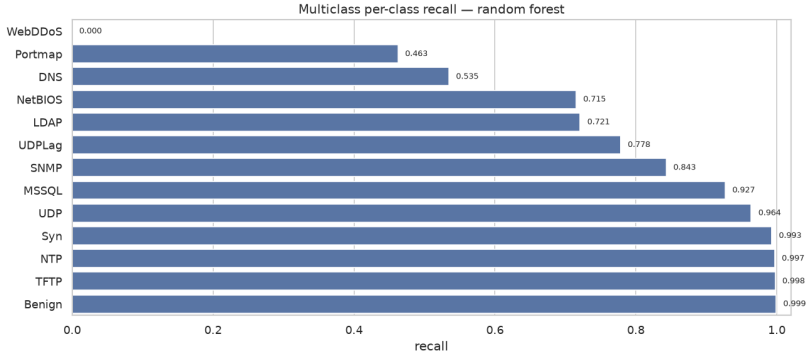
E1 — le multiclasses casse le score

- Binaire RF : Macro-F1 = 0.999.
- 13 classes RF : Macro-F1 = 0.757, Weighted-F1 = 0.982.
- Sans `Protocol` : Macro-F1 = 0.758 (Δ = 0.001).

H1 soutenue. Le score binaire ne prouve pas la compréhension des types.



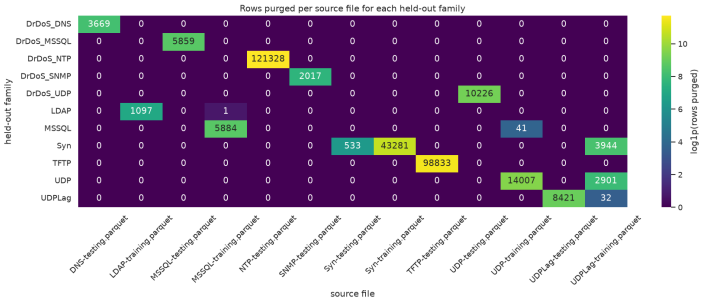
E1 — les familles rares paient



Le Weighted-F1 reste haut ; le Macro-F1 révèle les familles rares.

E2 — Leave-One-Attack-Out

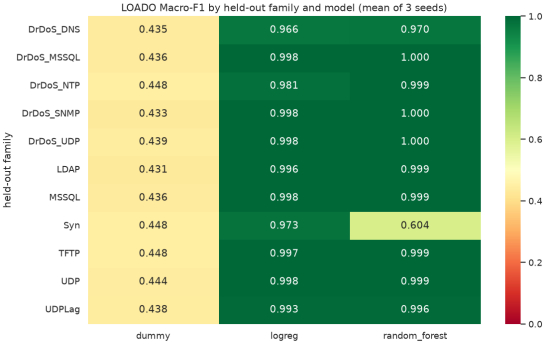
- 11 familles ≥ 1 000 lignes après dédoublonnage.
- Purge de la famille dans les 17 fichiers.
- Test équilibré : famille inconnue + Benign apparié.
- 11 × 3 modèles × 3 graines = **99 fits**.
- Exclusion : DrDoS_LDAP 993, Portmap 400, NetBIOS 374, DrDoS_NetBIOS 311, WebDDoS 49.



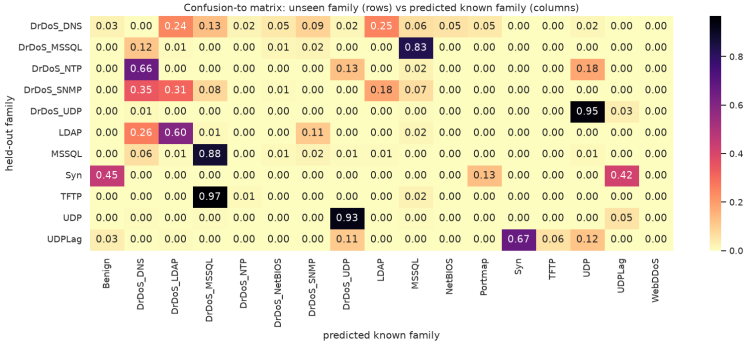
E2 — la généralisation est asymétrique

- Dix familles sur onze restent au-dessus de 0,96 (neuf au-dessus de 0,99).
- Cas dur : **Syn** — Macro-F1 0.604 avec la RF (rappel ≈ 0,30), mais 0.973 avec la régression logistique.
- Le FPR reste bas : c'est le **rappel** qui s'effondre, pas les fausses alertes.

H2 soutenue de façon asymétrique. La famille et le modèle comptent.



E2 — à quelle famille connue ressemble l’inconnue ?

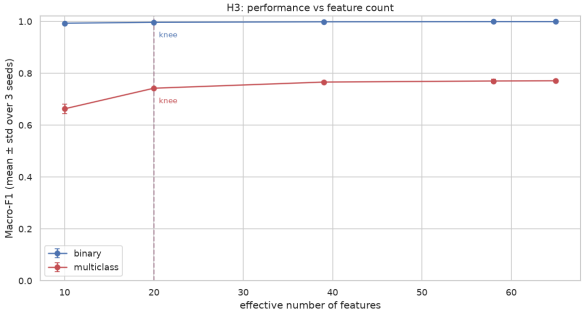


Cette matrice est plus actionnable qu’un F1 : elle indique la famille et la mitigation que l’analyste va essayer en premier.

E3 — combien de features ?

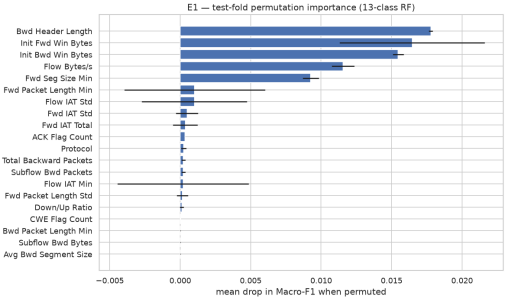
- Top-10 : Macro-F1 binaire 0.993 vs 0.999 avec toutes.
- En 13 classes : 0.663 vs 0.771 — la chute est plus nette.
- Latence quasi identique (46.94 vs 46.99 ms/1k).
- Le gain de latence du RF est faible : 300 arbres dominent le coût.

H3 partiellement soutenue.



XAI — ce que le modèle regarde

- Feature la plus importante : **Bwd Header Length** (importance moyenne 0.018).
- Puis fenêtres TCP initiales (`Init Fwd/Bwd Win Bytes`) et `Flow Bytes/s`.
- Les tailles moyennes et bulk-rates ne dominent pas ; sur Syn, ACK/URG flags comptent.
- Importance par permutation calculée sur le **test**.



Réponses aux questions

- **Q1** — Les familles qui généralisent le mieux recouvrent le profil d'en-tête/fenêtre et de débit des familles vues ; Syn est l'exception pour la RF.
- **Q2** — Non : binaire ≠ identification de famille.
- **Q3** — Quelques dizaines de features suffisent pour l'essentiel ; les familles rares perdent leur rappel en premier.
- **Q4** — Rappel attaque, FPR, latence et débit ; pas l'accuracy.

Limites et conclusion

- Capture de laboratoire 2019, pas de trafic chiffré ni de dérive.
- Test E2 équilibré 1:1, pas la prévalence de production.
- Familles rares exclues des rotations LOADO.
- Latence mesurée sur un laptop, pas sur un équipement réseau.
- Labels contradictoires : certains flux sont indistinguables.

1. Le binaire est un bon **triage**, pas un produit de classification.
2. La généralisation dépend de la **famille** et du **modèle** : il faut une classe « inconnue » et une revue humaine.
3. La réduction de features aide, mais le choix du modèle reste décisif pour le temps réel.
4. Les métriques de décision sont le rappel par famille, le FPR et la latence.

Merci — questions.